WU INKUBASI - PENUGASAN WEEK I

Gaia Aisha Purnomo

255150200111072

Cryptography

Beaufort

Beaufort, kind of like Vigenere, but different

aasaaaba26{njitxgkh_haxft_vcib_flckaewy_bbll_h3l4}

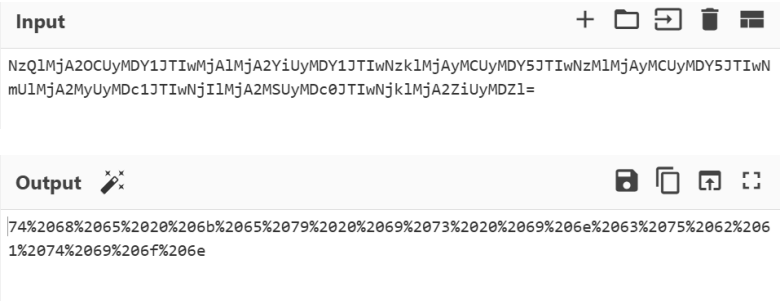
NzQlMjA2OCUyMDY1JTIwMjAlMjA2YiUyMDY1JTIwNzklMjAyMCUyMDY5JTIwNzMlMjAyMCUyMDY5JTIwNmUlMjA2MyUyMDc1JTIwNjIlMjA2MSUyMDc0JTIwNjklMjA2ZiUyMDZl=

Author: eightypointone

Solve

Dari judulnya disampaikan bahwa challenge ini menggunakan Beaufort Cipher. Di baris kedua deskripsi juga diberikan string yang terlihat sekali merupakan flag yang masih perlu di decode.

Seperti halnya Vigenere, Beaufort membutuhkan kunci untuk memecahkan hasil encodingnya. Jika kita melihat ke baris 3, ada string dengan encode base64 (terlihat dari akhir string yang memiliki tanda =). Dugaan awal adalah di dalam baris 3 terdapat kunci untuk flag di baris 2.



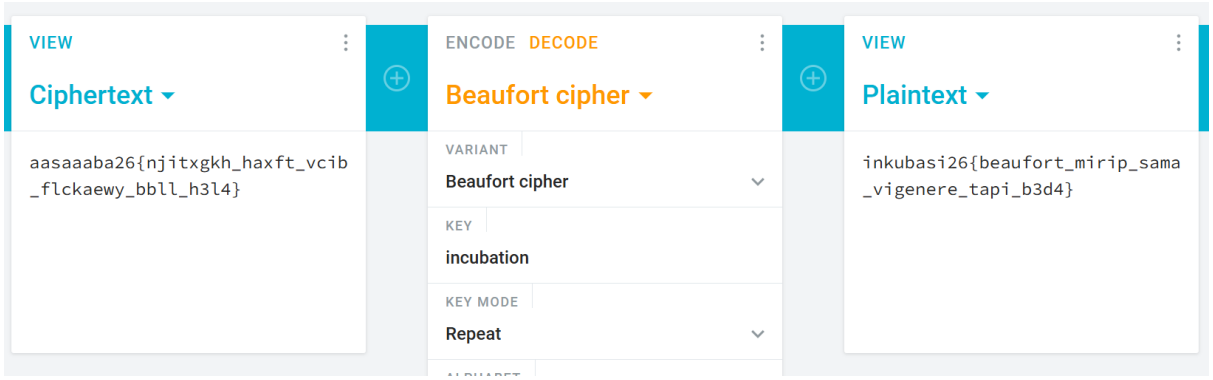
Setelah dimasukkan ke dalam tools online, ditemukan output sebagai berikut. Setelah saya cari ternyata ini merupakan bentuk URL Encoding. Langsung saja kit gunakan tools online untuk decode,

74 68 65 20 6b 65 79 20 69 73 20 69 6e 63 75 62 61 74 69 6f 6e

Ini adalah hasil decode-nya.

Hasil decode masih dalam bentuk hex, jadi kita ubah bentuknya, hasilnya adalah string berikut → **the key is incubation**

Masukkan flag ke dalam Beaufort decoder beserta kuncinya



FLAG : inkubasi26{beaufort_mirip_sama_vigenere_tapi_b3d4}

DSA Trouble

Agen rahasia POROS Faruqi menggunakan DSA untuk melakukan penciptaan tanda tangan. Tapi sayangnya, agen ini menggunakan nonce (k) yang sama untuk dua pesan berbeda. Dengan informasi yang tersedia, temukan private key agen tersebut.

Diberikan: q = 283 r = 118 s1 = 263 s2 = 163 H(m1) = 111 H(m2) = 222

Author: eightypointone

Peraturan Pengerjaan:

1. Wajib melakukan implementasi menggunakan kode Python
2. Wajib menjelaskan langkah-langkah penyelesaian, termasuk perubahan yang digunakan
3. Hasil dari nilai private key wajib di masukkan ke dalam format flag: inkubasi26{x}

Solve

Diketahui :

1. nonce (k) sama
2. $q = 283$
3. $r = 118$
4. $S_1 = 263$ $S_2 = 163$
5. $H(m)_1 = 111$ $H(m)_2 = 222$

$$S = (k^{-1}(H(m) + x.r)) \bmod q$$

Buat 2 persamaan

$$S_1 = (k^{-1}(H(m)_1 + x.r)) \bmod q \ldots (1)$$
$$S_2 = (k^{-1}(H(m)_2 + x.r)) \bmod q \ldots (2)$$

$$S_1 - S_2 = k^{-1}(H(m)_1 + x.r) \bmod q - k^{-1}(H(m)_2 + x.r) \bmod q$$
$$S_1 - S_2 = k^{-1}[(H(m)_1 + x.r) - (H(m)_2 + x.r)] \bmod q$$
$$S_1 - S_2 = k^{-1}(H(m)_1 - H(m)_2) \bmod q$$

$$k = \frac{H(m)_1 - H(m)_2}{S_1 - S_2} \bmod q$$
$$k = \frac{111 - 222}{263 - 163} \bmod 283$$
$$k = 47 \text{ (pake extended Euclidean)}$$

Cari private key (x)

$$S_2 = k^{-1}(H(m)_2 + x.r) \bmod q$$
$$S_2.k = H(m)_2 + x.r \bmod q$$
$$x.r = S_2.k - H(m)_2 \bmod q$$
$$x = \frac{S_2.k - H(m)_2 \bmod q}{r}$$
$$x = \frac{163.47 - 222 \bmod 283}{118}$$
$$x = 12250 \times 118^{-1} \bmod 283$$

$$12250 \bmod 283 = 81$$
$$118^{-1} \bmod 283$$
$$\downarrow$$
$$118x \equiv 1 \pmod{283}$$
$$x = 12$$
$$x = 81 \times 12 \bmod 283$$
$$x = 123$$

Berikut merupakan implementasi kode Python-nya

```python
# DSA Nonce Reuse Attack — Koreksi
q   = 283
r   = 118
s1  = 263
s2  = 163
Hm1 = 111
Hm2 = 222

# Langkah 1: Hitung k
# k = (H(m1) - H(m2)) * modinv(s1 - s2, q) mod q
diff_H = (Hm1 - Hm2) % q        # (111 - 222) mod 283 = -111 mod 283 = 172
diff_s = (s1 - s2) % q           # (263 - 163) mod 283 = 100

modinv_diff_s = pow(diff_s, -1, q)  # modinv(100, 283) = 150
k = (diff_H * modinv_diff_s) % q
print(f"[*] modinv(100, 283) = {modinv_diff_s}")
print(f"[*] Nonce k          = {k}")

# Langkah 2: Hitung private key x
# x = (s1*k - H(m1)) * modinv(r, q) mod q
numerator = (s1 * k - Hm1) % q      # (263*47 - 111) mod 283 = 12250 mod 283 = 81
modinv_r  = pow(r, -1, q)            # modinv(118, 283) = 12
x = (numerator * modinv_r) % q
print(f"[*] modinv(118, 283) = {modinv_r}")
print(f"[*] Private key x    = {x}")

# Verifikasi
k_inv     = pow(k, -1, q)
s1_check  = (k_inv * (Hm1 + x * r)) % q
s2_check  = (k_inv * (Hm2 + x * r)) % q
print(f"\n[+] Verifikasi:")
print(f"    s1 expected={s1}, computed={s1_check} → {'✓' if s1_check==s1 else '✗'}")
print(f"    s2 expected={s2}, computed={s2_check} → {'✓' if s2_check==s2 else '✗'}")

print(f"\n[FLAG] inkubasi26{{{x}}}")
```

FLAG : inkubasi26{123}

Binary Exploitation

Diagnosa

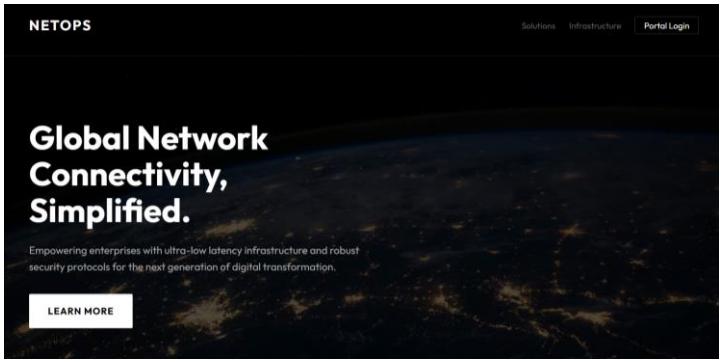
Empowering enterprises with ultra-low latency infrastructure and robust security protocols for the next generation of digital transformation.

http://netops.zenc.cc/

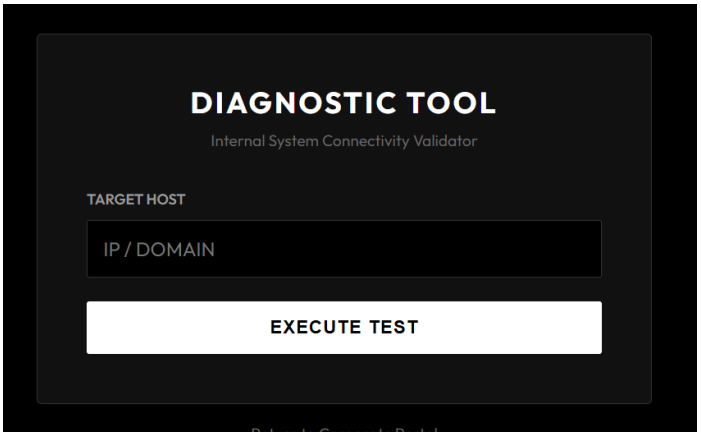
Author: zenc

Solve

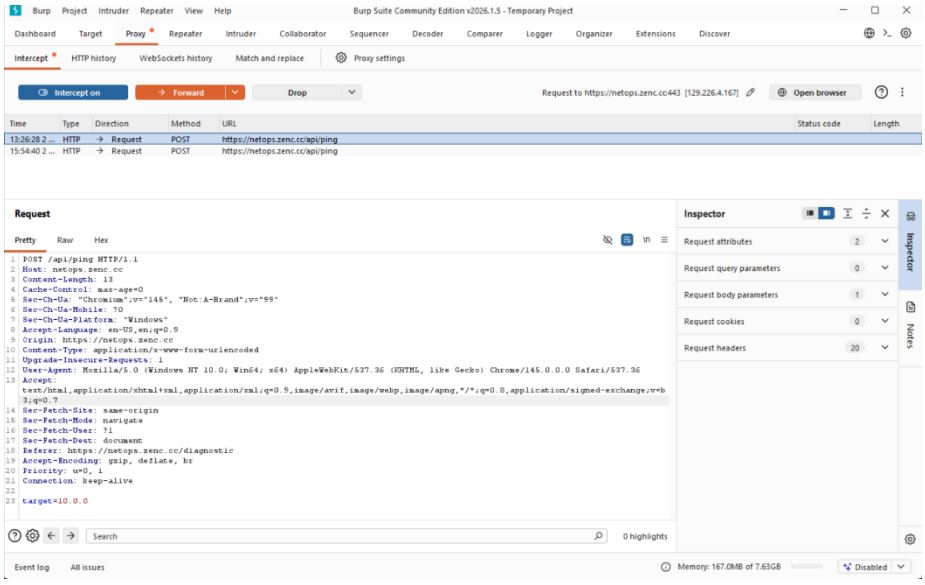
Saat masuk ke dalam link, akan muncul page di bawah.



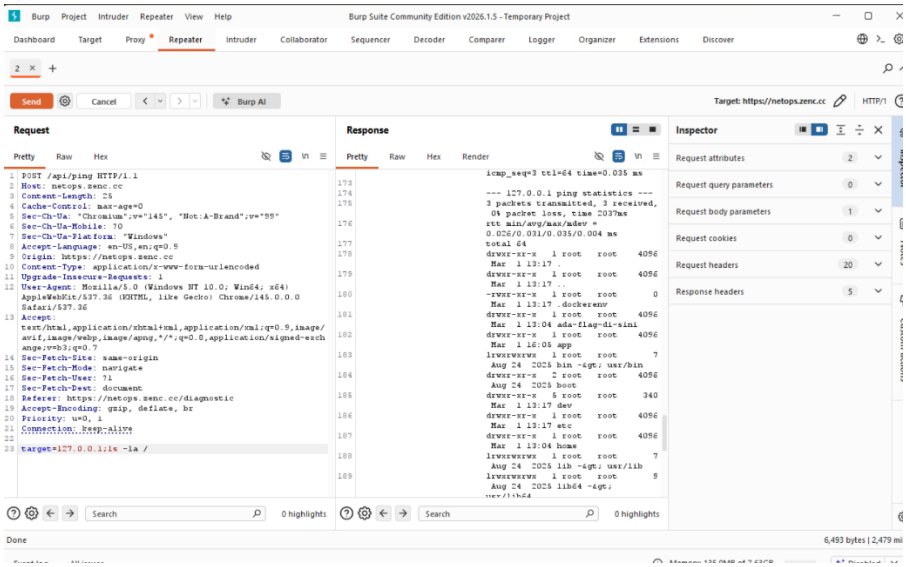
Klik **Portal Login** di pojok kanan atas, lalu akan muncul page berikut.



Melihat dari materi kemarin, yang paling memungkinkan sebagai metode exploit adalah Command Line Intercept. Masukkan page tersebut ke dalam burpsuite lalu klik kanan area yang diblok biru, pilih Send to Repeater.



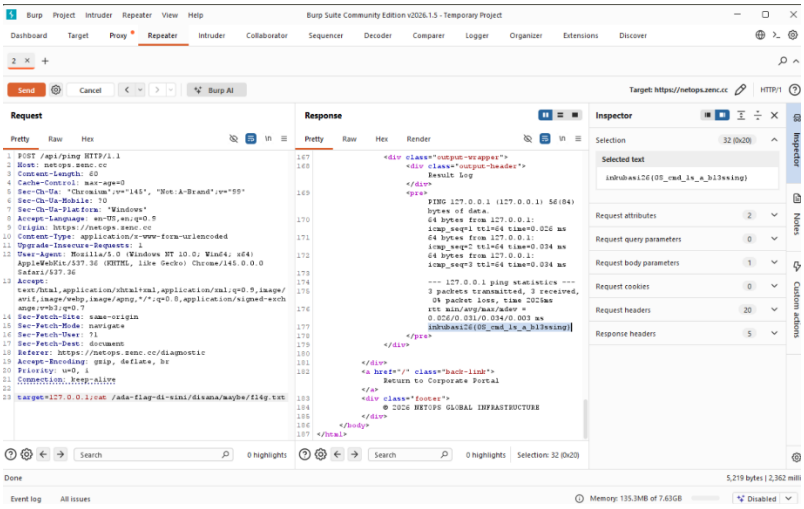
Masuk ke dalam repeater, lalu coba isi target dengan IP random lalu berikan ; dan ketik ls / untuk melihat folder di dalam root.



Disitu sudah terlihat folder yang mencurigakan → ada-flag-di-sini. Karena command linux berhasil dijalankan berarti ini benar chall terkait Command Line Intercept, penyebab web ini vuln dapat dilihat pada file app.py sebagai berikut :

```
if not target:
    return &#34;Target cannot be empty!&#34;, 400
try:
    command = f&#34;ping -c 3 -n {target}&#34;
    process = subprocess.run(command, shell=True, stdout=subprocess.PIPE, stderr=subprocess.STDOUT, text=True)
    return render_template(&#39;diagnostic.html&#39;,
    output=process.stdout, target=target) except Exception as e: return render_template(&#39;diagnostic.html&#39;, output=f&#34;Unexpected Error: {str(e)}&#34;, target=target)
```

Selanjutnya kita masuk ke folder ada-flag-di-sini. Akan ada beberapa folder, yaitu disini, disana, disitu, dan 1 fakeflag. Setelah dicek satu per satu, flag akan ditemukan di path → ada-flag-di-sini/disana/maybe/fl4g.txt



FLAG : inkubasi26{OS_cmd_is_a_bl3ssing}

Whispers in The Wire

A fortress built on a blacklist is a fortress built on sand.

The warden has taken away your spaces. He has taken away your separators. He has even erased the names of the tools you seek to use.

But the shell is deep, and its vocabulary is vast. When the front gate is locked, and the guards are watching the spaces... how will you ask the system to yield its secrets?

Look beyond the visible characters. Read between the lines.

http://10.34.9.91:5006/

atachment: https://drive.usercontent.google.com/uc?id=15WyhMi7SmKOspbBrtEZ3jXzd_V8JwX3a&export=download

Author:Bagas

Solve

Dilihat dari soal, ada beberapa karakter yang tidak bis akita gunakan untuk Command Injection, yaitu spaces, separators, dan "tools you seek to use" → Command Linux

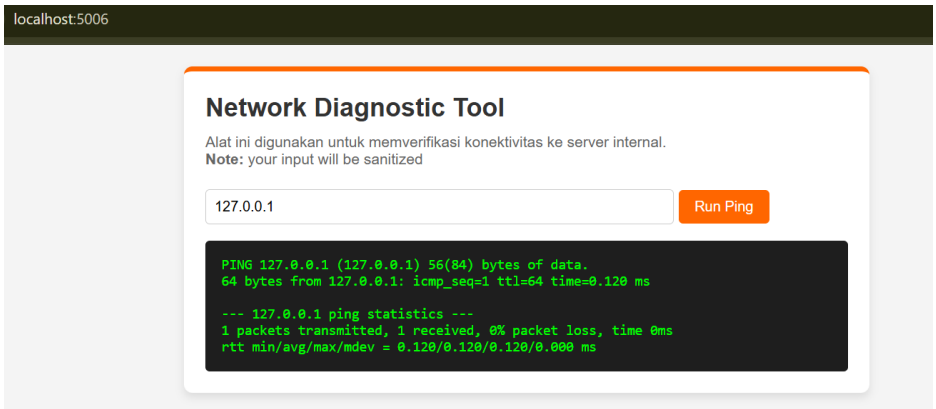
Jika kita lihat ke dalam file index.php dalam attachment, terdapat penjelasan lebih jelas terkait karakter apa saja yang dilarang.

```
// STRICT BLACKLIST WAF
            $blacklist = [
                ' ',
                ';',
                '|',
                '&',
                '$',
                '`',
                'cat',
                'ls',
                'flag',
                'whoami'
            ];
```

Pertama-tama, jalankan web secara lokal lewat docker untuk bereksperimen dengan payload. Gunakan port lokal dan port container jika ingin membuka web di dalam browser. Jika ingin membuka di dalam komputer, cukup masukkan command curl https://172.17.0.2

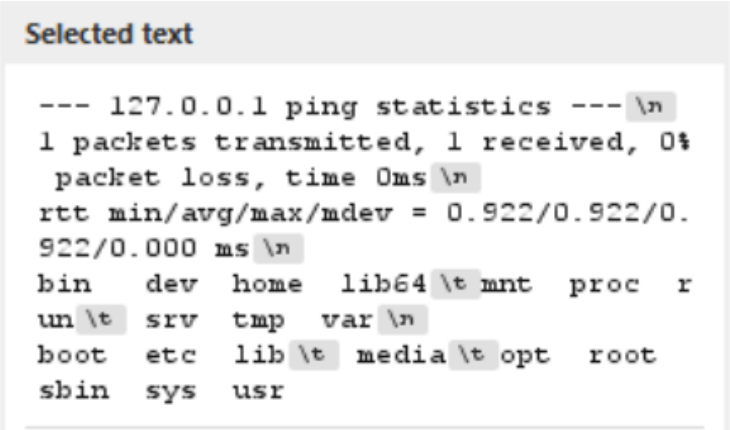
```
earthgoddess@Gaia:~/web-week1-cmd-atach/web-week1-cmd$ cat Dockerfile | grep -i expose
EXPOSE 80
earthgoddess@Gaia:~/web-week1-cmd-atach/web-week1-cmd$ docker run -p 5006:80 myproject
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.17.0.2. Set the 'ServerNa
me' directive globally to suppress this message
AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 172.17.0.2. Set the 'ServerNa
me' directive globally to suppress this message
[Mon Mar 02 09:07:23.502131 2026] [mpm_prefork:notice] [pid 1:tid 1] AH00163: Apache/2.4.66 (Debian) PHP/8.2.30 configured -
- resuming normal operations
[Mon Mar 02 09:07:23.502291 2026] [core:notice] [pid 1:tid 1] AH00094: Command line: 'apache2 -D FOREGROUND'
172.17.0.1 - - [02/Mar/2026:09:07:34 +0000] "GET / HTTP/1.1" 200 1044 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWe
bKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36"
172.17.0.1 - - [02/Mar/2026:09:07:34 +0000] "GET /favicon.ico HTTP/1.1" 404 529 "http://localhost:5006/" "Mozilla/5.0 (Windo
ws NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36"
172.17.0.1 - - [02/Mar/2026:09:07:42 +0000] "POST / HTTP/1.1" 200 1193 "http://localhost:5006/" "Mozilla/5.0 (Windows NT 10.
0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36"
172.17.0.1 - - [02/Mar/2026:09:08:33 +0000] "-" 408 0 "-" "-"
```

Di sini saya membuka web lewat browser.



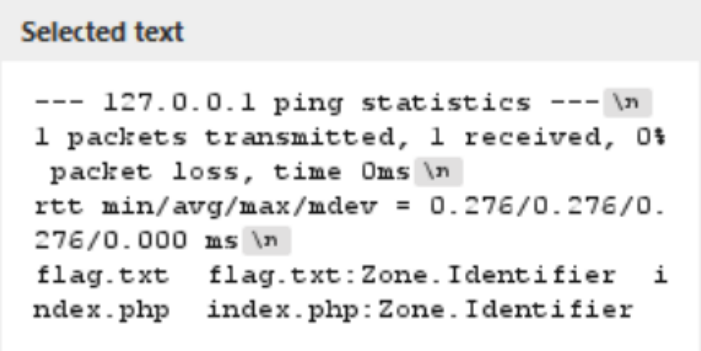
Masukkan page ke dalam burpsuite lalu mulai trial and error payload. Coba pakai dir karena dia termasuk command yang tidak dilarang

Payload : ip=127.0.0.1%0adir%09/ → Akan muncul response berikut.



Coba cek ke dalam folder var karena di dalamnya terdapat Lokasi default web server di Linux.

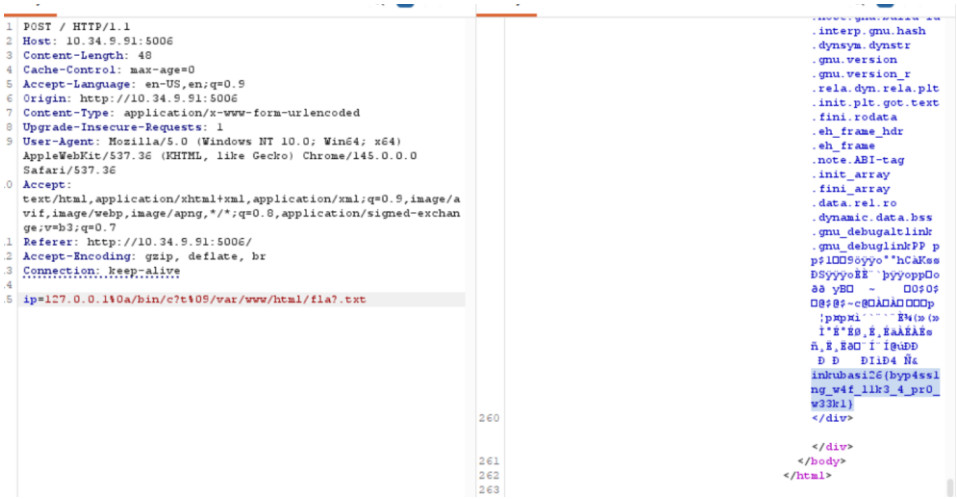
Command : ip=127.0.0.1%0adir%09/var/www/html → Akan muncul list file berikut



Bypass command cat dan file flag dengan globbing

→ ip=127.0.0.1%0a/bin/c?t%09/var/www/html/fla?.txt. Command ini akan memunculkan string berikut inkubasi26{dummmy_flag_for_local_testing}. Berarti kita sudah menemukan

command untuk mendapatkan flag. Masukkan alamat web asli ke dalam burpsuite dan masukkan command yang sama.



FLAG : inkubasi26{byp4ss1ng_w4f_l1k3_4_pr0_w33k1}